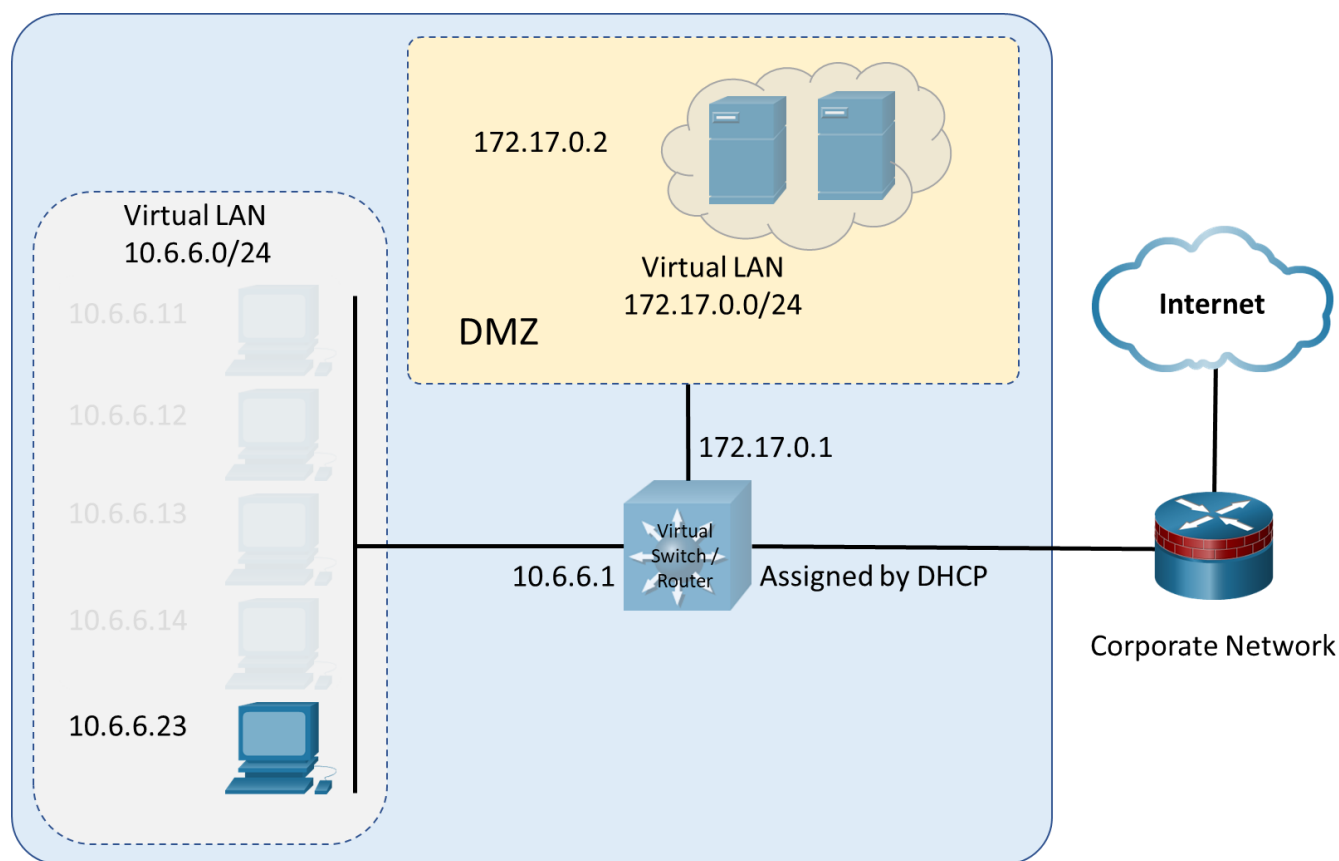


Lab - Enumeration with Nmap (Version Instructeur)

Note de l'instructeur : La couleur rouge de la police ou les surbrillances grises indiquent le texte qui apparaît uniquement dans la copie de l'instructeur.

Topologie



Réaliser par : Audes Mariana MOUSSAVOU MOUSSAVOU

Encadré par : Pr. Azeddine KHIAT

Année universitaire 2025-2026

Objectifs

Nmap est un puissant outil open-source pour la cartographie et la découverte de réseaux. Dans ce laboratoire, vous utiliserez Nmap dans le cadre de votre stratégie de reconnaissance active.

- Explorer Nmap
- Effectuer des analyses Nmap de base

Contexte/scénario

Une capture Wireshark montre une activité inhabituelle sur une machine du réseau DMZ 10.6.6.0. On vous a demandé d'effectuer une reconnaissance active sur la machine pour déterminer les services qu'elle peut offrir et s'il existe des applications vulnérables qui pourraient présenter des problèmes de sécurité. L'adresse IP de l'ordinateur suspect est 10.6.6.23. Vous avez accès à un système Kali Linux sur le réseau 10.6.6.0.

Ressources requises

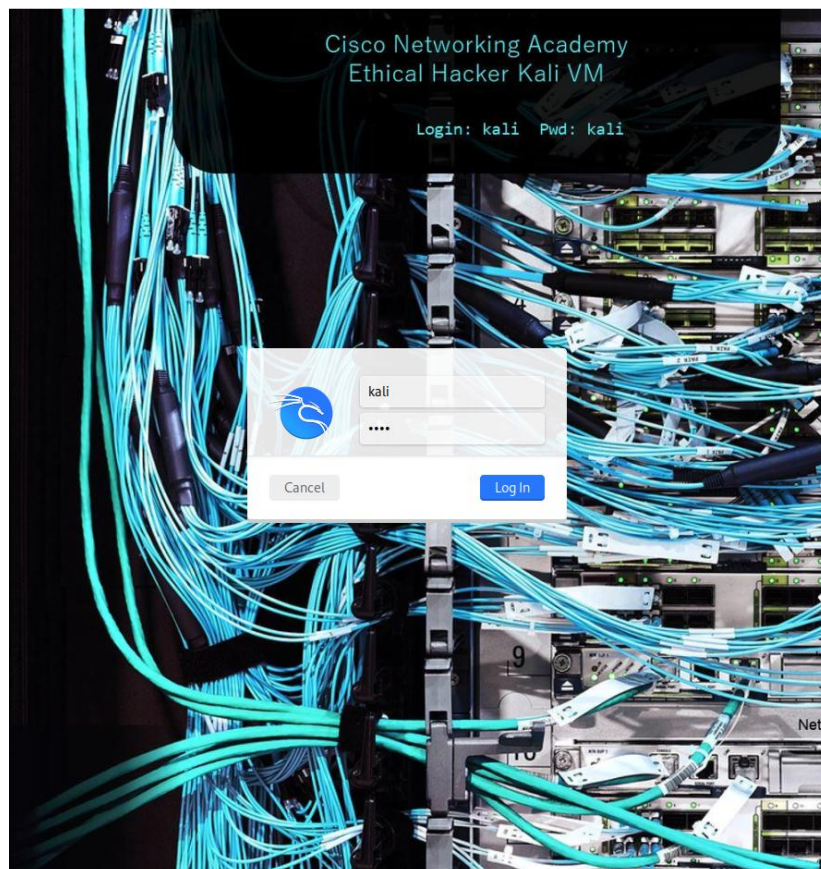
- Kali VM personnalisée pour le cours Ethical Hacker

Instructions

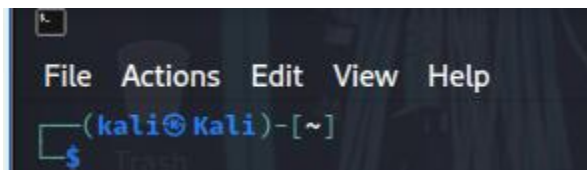
Part 1: Examiner Nmap

Step 1: Connectez-vous à Kali Linux et vérifiez l'environnement.

- Connectez-vous au système Kali avec le nom d'utilisateur kali et le mot de passe kali. Le bureau Kali s'affiche.



- b. Ouvrez une fenêtre de terminal.



- c. Vérifiez que Kali a une interface dans le réseau 10.6.6.0/24 en utilisant la commande ifconfig.

```
4: br-355ee7945a88: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:69:c6:2e:f8 brd ff:ff:ff:ff:ff:ff
    inet 192.168.0.1/24 brd 192.168.0.255 scope global br-355ee7945a88
        valid_lft forever preferred_lft forever
    inet6 fe80::42:69ff:fec6:2ef8/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
```

Nous avons exécuté **ip a** car la commande **ipconfig** génère des erreurs.

- d. Utilisez la **commande nmap -V** pour vérifier que Nmap est installé et pour afficher la version de Nmap. La sortie sera similaire à ce qui est indiqué ci-dessous.

```
(kali@Kali)-[~]
$ nmap -V
Nmap version 7.94 ( https://nmap.org )
Platform: x86_64-pc-linux-gnu
Compiled with: liblua-5.4.4 openssl-3.0.9 libssh2-1.10.0 libz-1.2.13 libpcap-1.10.4 nmap-libdnet-1.12
Compiled without:
Available nsock engines: epoll poll select
```

Step 2: Examiner les options et fonctionnalités Nmap

- a. L'utilisation de la commande **nmap** sans spécifier d'options ou de cibles renvoie une liste d'options Nmap couramment utilisées. Pour accéder au système d'aide Nmap, utilisez la commande **nmap -h**. La sortie de l'aide est divisée en sections en fonction du type de détection pris en charge par l'option.
- b. La page man de Nmap fournit des informations supplémentaires. Pour accéder à la page man, entrez la commande **man nmap**. Pour quitter les pages de manuel, appuyez sur **q** et revenir à l'invite du terminal.

Utilisez la page man pour Nmap pour compléter la table.

Options NMAP courantes

Option	Description
-A	Analyse agressive qui permet la détection du système d'exploitation, la détection de version, l'analyse de script et traceroute
-O	Active la détection du système d'exploitation
-p <port ranges>	Permet d'analyser des ports ou des plages de ports spécifiques
-sF	Effectue une analyse FIN TCP
-sn	Effectue une analyse de la découverte de l'hôte
-sS	Effectue une analyse TCP SYN

Option	Description
-sT	Effectue une analyse TCP Connect
-sV	Sonde les ports ouverts pour déterminer les informations de service/version
-T<0-5>	Définit le timing de l'analyse.Des nombres plus élevés produisent des résultats plus rapidement.Des analyses plus lentes échappent mieux à la détection.
-v	Augmente le niveau de détail de la sortie
--open	Ne signale que les ports ouverts (ou éventuellement ouverts)

Part 2: Effectuer des analyses Nmap de base

Step 1: Lancez une analyse Nmap de base de l'ordinateur cible.

- Pour analyser rapidement la zone démilitarisée à la recherche d'hôtes actifs, vous pouvez effectuer une analyse de découverte.Lors d'une analyse de découverte, l'hôte d'analyse envoie une requête d'écho ICMP (ping), un TCP SYN au port 443, un TCP ACK au port 80 et une demande d'horodatage ICMP.Une réponse à l'une des demandes indique que l'hôte est opérationnel et que la pile de protocoles IP sur l'hôte fonctionne.Saisissez la commande suivante pour analyser le réseau DMZ :

```
(kali@kali)-[~]
$ nmap -sn 10.6.6.0/24
Starting Nmap 7.94 ( https://nmap.org ) at 2026-02-11 19:21 UTC
Nmap scan report for 10.6.6.1
Host is up (0.0021s latency).
Nmap scan report for webgoat.vm (10.6.6.11)
Host is up (0.00073s latency).
Nmap scan report for juice-shop.vm (10.6.6.12)
Host is up (0.00053s latency).
Nmap scan report for dvwa.vm (10.6.6.13)
Host is up (0.0017s latency).
Nmap scan report for mutillidae.vm (10.6.6.14)
Host is up (0.00063s latency).
Nmap scan report for gravemind.vm (10.6.6.23)
Host is up (0.0051s latency).
Nmap scan report for 10.6.6.100
Host is up (0.00041s latency).
Nmap done: 256 IP addresses (7 hosts up) scanned in 15.95 seconds
```

Combien d'hôtes actifs se trouvent dans le réseau DMZ ?

Les réponses peuvent varier en fonction de l'environnement.Dans cet environnement virtuel personnalisé, il y en a 6, y compris l'hôte Kali Linux.

- L'hôte 10.6.6.23 a été identifié comme suspect lors d'une capture de Wireshark, et il est nécessaire d'effectuer une reconnaissance supplémentaire pour en savoir plus sur l'ordinateur et ses services.Utilisez la **commande nmap** pour exécuter une analyse par défaut sur l'hôte cible.

```
(kali@kali)-[~]
$ nmap 10.6.6.23
Starting Nmap 7.94 ( https://nmap.org ) at 2026-02-11 19:25 UTC
Nmap scan report for gravemind.vm (10.6.6.23)
Host is up (0.00014s latency).
Not shown: 994 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 0.10 seconds
```

Quels ports sont répertoriés comme ouverts sur l'hôte cible (10.6.6.23) ?

Les ports ouverts répertoriés sont : 21, 22, 53, 80, 139 et 445

Par défaut, Nmap effectue une analyse de connexion des 1000 ports TCP les plus courants. Cela utilise le logiciel de mise en réseau du système d'exploitation pour établir une connexion TCP complète. Ce type d'analyse crée beaucoup de trafic réseau et augmente la probabilité de détection par les services de détection d'intrusion. Vous pouvez également spécifier une analyse de connexion TCP à l'aide de l'option **de la commande nmap -sT**.

Le résultat de l'analyse de connexion inclut les codes d'état présentés dans le tableau :

Statut	Réponse reçue	Interprétation
Ouverture	TCP SYN-ACK	Il y a un service à l'écoute sur le port identifié.
Fermé	TCP RST	Il n'y a aucun service à l'écoute sur le port identifié.
Filtré	Pas de réponse ou message ICMP destination inaccessible reçu.	Le port est filtré par un pare-feu.

- c. L'option **-O** peut être utilisée pour obtenir des informations supplémentaires sur le système d'exploitation exécuté sur l'hôte cible. Certaines options Nmap nécessitent des autorisations supplémentaires et doivent être exécutées en tant que **root** ou à l'aide de la **commande sudo**. Pour rechercher des informations sur le système d'exploitation sur l'hôte cible, utilisez la **commande nmap -O**. Entrez le mot de passe de **kali** lorsque vous y êtes invité.

```
(kali@kali)-[~]
└─$ sudo nmap -O 10.6.6.23
[sudo] password for kali:
Starting Nmap 7.94 ( https://nmap.org ) at 2026-02-11 19:41 UTC
Nmap scan report for gravemind.vm (10.6.6.23)
Host is up (0.00015s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 02:42:0A:06:06:17 (Unknown)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.8
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.55 seconds
```

Quel système d'exploitation l'hôte cible exécute-t-il ?

Le système d'exploitation sur l'hôte est Linux 4.15 - 5.6.

Step 2: Obtenez des informations supplémentaires sur l'hôte et les services.

- a. Pour fournir des informations supplémentaires sur l'ordinateur cible, il est possible de combiner différentes options en une seule ligne de commande. La commande précédente a identifié plusieurs ports potentiellement ouverts sur l'hôte 10.6.6.23. Vous pouvez utiliser **-v**, **-p** et **-sV** pour trouver des informations supplémentaires sur les services exécutés sur les ports ouverts. Cette commande fournit des informations sur le service FTP exécuté sur le port 21 de la cible en mode détaillé, avec la synchronisation définie sur rapide (**-T4**) :

```
(kali㉿Kali)-[~]
$ nmap -v -p21 -sV -T4 10.6.6.23
Starting Nmap 7.94 ( https://nmap.org ) at 2026-02-11 19:43 UTC
NSE: Loaded 46 scripts for scanning.
Initiating Ping Scan at 19:43
Scanning 10.6.6.23 [2 ports]
Completed Ping Scan at 19:43, 0.00s elapsed (1 total hosts)
Initiating Connect Scan at 19:43
Scanning gravemind.vm (10.6.6.23) [1 port]
Discovered open port 21/tcp on 10.6.6.23
Completed Connect Scan at 19:43, 0.00s elapsed (1 total ports)
Initiating Service scan at 19:43
Scanning 1 service on gravemind.vm (10.6.6.23)
Completed Service scan at 19:43, 0.01s elapsed (1 service on 1 host)
NSE: Script scanning 10.6.6.23.
Initiating NSE at 19:43
Completed NSE at 19:43, 0.00s elapsed
Initiating NSE at 19:43
Completed NSE at 19:43, 0.00s elapsed
Nmap scan report for gravemind.vm (10.6.6.23)
Host is up (0.00046s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
Service Info: OS: Unix

Read data files from: /usr/bin/../share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.38 seconds
```

Qu'avez-vous découvert sur le type et la version du serveur FTP exécuté sur l'hôte ?

La commande répertorie la version de FTP exécutée sur l'ordinateur en tant que vsftpd 3.0.3.

- b. L'option **-A** exécute la détection du système d'exploitation, la détection de version, l'analyse de script et traceroute. L'analyse **-A** peut être très intrusive et sera donc détectée par de nombreux systèmes IDS, alors assurez-vous d'avoir la permission avant de tenter cette analyse en dehors de l'environnement de laboratoire. Pour collecter plus d'informations concernant le service FTP, entrez la commande **nmap -A -p21 10.6.6.23**.

L'exemple de sortie détaillée de cette commande est présenté ci-dessous :

```
(kali@kali)-[~]
$ nmap -p21 -sV -A 10.6.6.23
Starting Nmap 7.94 ( https://nmap.org ) at 2026-02-11 19:44 UTC
Nmap scan report for gravemind.vm (10.6.6.23)
Host is up (0.00064s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| -rw-r--r--    1 0      0      16 Aug 13  2021 file1.txt
| -rw-r--r--    1 0      0      16 Aug 13  2021 file2.txt
| -rw-r--r--    1 0      0      29 Aug 13  2021 file3.txt
| -rw-r--r--    1 0      0      26 Aug 13  2021 supersecretfile.txt
| ftp-syst:
|  STAT:
|  FTP server status:
|    Connected to 10.6.6.1
|    Logged in as ftp
|    TYPE: ASCII
|    No session bandwidth limit
|    Session timeout in seconds is 300
|    Control connection is plain text
|    Data connections will be plain text
|    At session startup, client count was 3
|    vsFTPd 3.0.3 - secure, fast, stable
|_End of status
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.49 seconds

(kali@kali)-[~]
```

- c. Examinez la sortie de la **commande nmap -A**. Notez que la sortie indique qu'une connexion a été établie entre le système Kali Linux et le service FTP cible.

Combien de fichiers sur le serveur FTP sont accessibles via cette connexion ?

Quatre fichiers texte sont accessibles.

Quelle faiblesse dans la configuration du serveur FTP a permis au système Kali Linux de se connecter au serveur FTP ?

Le serveur FTP est configuré pour autoriser les connexions anonymes.

Step 3: Étudier les services SMB à l'aide de scripts

Le protocole SMB (Server Message Block) est un protocole de partage de fichiers réseau pris en charge sur les ordinateurs Windows et par SAMBA sous Linux. SMB permet aux applications de lire et d'écrire des fichiers ou de demander des services sur un réseau. Les partages publics ouverts ou les périphériques partagés, tels que les serveurs d'impression d'un réseau, sont accessibles via SMB.

- a. L'analyse précédente des ports ouverts sur l'ordinateur cible indique que les ports SMB 139 et 445 sont ouverts. Pour obtenir plus d'informations sur ces ports, utilisez les options de commande **-A** et **-p**. L'option **-A** exécute plusieurs fonctions, notamment l'exécution des scripts par défaut. Spécifiez plusieurs ports à analyser en les répertoriant séparément avec une virgule entre eux.

```
(kali㉿kali)-[~]
$ nmap -A -p139,445 10.6.6.23
Starting Nmap 7.94 ( https://nmap.org ) at 2026-02-11 19:46 UTC
Nmap scan report for gravemind.vm (10.6.6.23)
Host is up (0.00054s latency).

PORT      STATE SERVICE      VERSION
139/tcp    open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp    open  netbios-ssn  Samba smbd 4.9.5-Debian (workgroup: WORKGROUP)
Service Info: Host: GRAVEMIND

Host script results:
| smb2-security-mode:
|   3:1:1:
|_  Message signing enabled but not required
| smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.9.5-Debian)
|   Computer name: gravemind
|   NetBIOS computer name: GRAVEMIND\x00
|   Domain name: \x00
|   FQDN: gravemind
|_  System time: 2026-02-11T19:46:25+00:00
| smb2-time:
|   date: 2026-02-11T19:46:24
|_  start_date: N/A
| smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.53 seconds
```

- b. Examinez les informations renvoyées par l'analyse Nmap. À partir de ces informations, on peut déterminer que l'ordinateur cible est membre du groupe de travail par défaut, nommé WORKGROUP, et que SMB est pris en charge sur cet hôte via SAMBA sous Linux.

Quel est le nom de l'ordinateur NetBIOS attribué à l'hôte cible ?

Plusieurs réponses sont possibles. Par exemple, le nom de l'ordinateur NetBIOS peut être 868CF29B394C.

- c. Nmap contient le puissant moteur de script Nmap (NSE), qui permet la programmation de diverses options Nmap et actions conditionnelles à effectuer à la suite des réponses. NSE a des scripts intégrés qui énumèrent les utilisateurs, les groupes et les partages réseau. L'un des scripts les plus couramment utilisés pour la découverte SMB est le **script smb-enum-users.nse**. Utilisez le script Nmap NSE avec la commande :

```
(kali㉿Kali)-[~]
$ nmap --script smb-enum-users.nse -p139,445 10.6.6.23
Starting Nmap 7.94 ( https://nmap.org ) at 2026-02-11 19:50 UTC
Nmap scan report for gravemind.vm (10.6.6.23)
Host is up (0.00097s latency).

PORT      STATE SERVICE
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds

Host script results:
| smb-enum-users:
|   GRAVEMIND\arbiter (RID: 1001)
|     Full name:
|     Description:
|     Flags:      Normal user account, Password not required, Account disabled
|   GRAVEMIND\masterchief (RID: 1000)
|     Full name:
|     Description:
|     Flags:      Normal user account, Password not required, Account disabled
|_
Nmap done: 1 IP address (1 host up) scanned in 0.22 seconds
```

Le script a-t-il révélé des noms d'utilisateur SMB sur l'hôte cible ? Dans l'affirmative, combien ?

Deux noms d'utilisateur, arbitre et masterchief.

- d. Un grave problème de sécurité est l'existence de répertoires partagés publiquement (dossiers). Vous pouvez énumérer les partages réseau à l'aide d'un autre script NSE, `smb-enum-shares.nse`. Pour rechercher des répertoires partagés sur l'ordinateur cible. Utilisez le script d'énumération de partage Nmap avec la commandes :

```
(kali㉿Kali)-[~]
$ nmap --script smb-enum-shares.nse -p445 10.6.6.23
Starting Nmap 7.94 ( https://nmap.org ) at 2026-02-11 19:52 UTC
Nmap scan report for gravemind.vm (10.6.6.23)
Host is up (0.00056s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds
```

```
Host script results:
| smb-enum-shares:
|   account_used: <blank>
|   \\10.6.6.23\IPC$:
|     Type: STYPE_IPC_HIDDEN
|     Comment: IPC Service (Samba 4.9.5-Debian)
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\tmp
|     Anonymous access: READ/WRITE
|   \\10.6.6.23\print$:
|     Type: STYPE_DISKTREE
|     Comment: Printer Drivers
|     Users: 0
|     Max Users: <unlimited>
|     Path: C:\var\lib\samba\printers
|     Anonymous access: READ/WRITE
|   \\10.6.6.23\workfiles:
|     Type: STYPE_DISKTREE
|     Comment: Confidential Workfiles
|     Users: 0
|     Max Users: <unlimited>
|     Path: C:\var\spool\samba
|     Anonymous access: READ/WRITE
|_
Nmap done: 1 IP address (1 host up) scanned in 7.45 seconds
```

Examinez la sortie créée par le **script smb-enum-shares**. Dans la sortie, les noms de partage qui se terminent par un caractère « \$ » représentent des partages masqués qui incluent des partages système et administratifs.

Combien de partages masqués ont été découverts sur l'hôte cible ?

2

Quel risque de sécurité grave est découvert dans cette sortie de script ?

Accès anonyme : LECTURE/ÉCRITURE.

Il existe des scripts préprogrammés qui peuvent fournir des fonctionnalités de découverte SMB supplémentaires si un compte utilisateur autorisé est disponible. Prenez le temps d'examiner certains des scripts NSE qui énumèrent les systèmes Windows et SAMBA.

Questions de réflexion

1. Nmap est un outil puissant pour la découverte de réseau. Pensez aux façons dont Nmap peut découvrir et énumérer les ordinateurs que vous avez utilisés dans ce laboratoire. Comment Nmap peut-il être utilisé par les techniciens réseau internes pour inventorier et sécuriser les ordinateurs locaux ? Comment ces mêmes

outils peuvent-ils être utilisés par des acteurs malveillants pour effectuer une reconnaissance avant une attaque ?

Plusieurs réponses sont possibles. Les analyses Nmap peuvent être utilisées pour identifier les périphériques actifs sur un réseau. Les analyses de base permettront de découvrir les ports ouverts et les services qui peuvent avoir besoin d'être sécurisés. L'accès anonyme aux fichiers FTP ou aux partages réseau peut être détecté et corrigé ou limité. Les acteurs malveillants peuvent utiliser ces mêmes fonctions pour trouver des ordinateurs susceptibles d'être vulnérables aux attaques.

2. Si vous deviez créer un rapport sur l'état de l'hôte cible (10.6.6.23), quels risques de sécurité graves incluriez-vous dans votre rapport ?

Plusieurs réponses sont possibles. Le rapport comprend des versions vulnérables de services, des partages ouverts, un accès anonyme à FTP et des services inutiles ou non sécurisés.